

IBM QRADAR 101 - THREAT INVESTIGATION

Financial Sector Insider Threat & Lateral Movement Analysis

1. EXECUTIVE SUMMARY

This comprehensive threat investigation documents the identification and mapping of a targeted external compromise facilitated by a malicious internal actor within a financial institution's infrastructure.

The investigation revealed that an insider employee, identified as **sami**, actively collaborated with an external threat actor. The attack lifecycle commenced via a phishing vector deploying a malicious file named `important_instructions.docx` on an employee workstation belonging to **nour**. Following the initial compromise, the attacker executed memory injection (`CreateRemoteThread`) to hide inside legitimate Windows processes, conducted internal network discovery, and utilized compromised domain credentials to pivot laterally. The threat actor ultimately targeted a sensitive corporate project, verified host defenses regarding logging evasion, and exfiltrated proprietary data back to an attacker-controlled infrastructure.

2. INCIDENT INVESTIGATION & CORE ANALYSIS

Q1: How many log sources available?

The initial environmental assessment required auditing configured data streams within the SIEM environment. Navigating to Admin → Data Sources → Log Sources within the QRadar console revealed the complete deployment scope listed at the bottom of the user interface.

Answer: 15

Q2: What is the IDS software used to monitor the network?

Network security monitoring capabilities were cross-referenced between the challenge configuration details and the configured log sources inside the QRadar asset management console.

Answer: Suricata

Q3: What is the domain name used in the network?

The corporate directory structure was identified by auditing successful authentication event records. Filtering the Log Activity tab for Windows Security Event ID 4624 (Successful Logon) revealed explicit log properties detailing account domains and target host names (e.g., HD-FIN-03.hackdefend.local).

Answer: hackdefend.local

Q4: Multiple IPs were communicating with the malicious server. One of them ends with “20”. Provide the full IP.

To isolate communication nodes interacting with the suspect destination infrastructure, the explicit authentication filter was cleared. Modifying the primary interface display parameters from "Default" to group by "Source IP" isolated a distinct networking footprint ending in .20.

Answer: 192.168.20.20

Q5: What is the SID of the most frequent alert rule in the dataset?

To pinpoint high-volume security alerts generated by network monitoring systems, an event property filter was built around signature definitions. Filtering for "Rule SID is not N/A" yielded 109 matching events, with a dominant subset of 72 events sharing an identical rule identifier signaling DNS queries hitting suspicious Top-Level Domains ("ET INFO Observed DNS Query to .cloud TLD").

Answer: 2027865

Q6: What is the attacker’s IP address?

High-fidelity alerts correlated by the correlation engine were evaluated in the Offenses tab. A highly critical offense description noting "Excessive Firewall Denies Between Hosts containing Firewall — Deny to multiple internal source IP" explicitly tied the anomalous sweeping behavior to an external routing origin.

Answer: 192.20.80.25

Q7: The attacker was searching for data belonging to one of the company’s projects, can you find the name of the project?

The strategy shifted to evaluating execution artifacts inside Sysmon logs, tracking local administrative shells (cmd.exe, powershell.exe). Implementing a regex payload filter designed to catch command arguments exposed an explicit file discovery loop mapping to a PowerShell script directive.

Answer: project48

Q8: What is the IP address of the first infected machine?

To establish a clear incident timeline, the Log Activity view was categorized by High Level Category = Suspicious Activity (isolating early indicators like exploratory network mapping and port scans) and sorted in ascending chronological order.

Answer: 192.168.10.15

Q9: What is the username of the infected employee using 192.168.10.15?

Isolating the early-stage compromised endpoint footprint (192.168.10.15) within event logs allowed the extraction of identity attributes tied to session generation on that host asset.

Answer: nour

Q10: Hackers do not like logging, what logging was the attacker checking to see if enabled?

Threat actors systematically attempt to detect endpoint detection rules. A deeper payload query tracking regulatory modifications and system queries via regex flags caught an explicit command validating local system logging profiles.

Answer: ScriptBlockLogging

Q11: Name of the second system the attacker targeted to cover up the employee?

Following sequential event ordering from the initial weaponization phase on host 192.168.10.15, the threat actor targeted a separate management segment machine to mask user access paths.

Answer: MGNT-01

Q12: When was the first malicious connection to the domain controller (log start time - hh:mm:ss)?

Network telemetry logs directed at the infrastructure's Domain Controller (192.168.20.20) were analyzed. An anomalous process interaction was highlighted when a native text editor (notepad.exe) established outbound active network hooks over the wire.

Answer: 11:14:10

Q13: What is the md5 hash of the malicious file?

To extract initial threat indicators, logs were queried for cryptographic payload signatures. Filtering logs using "Payload Contains is hash" highlighted file metadata for an anomalous email attachment document distributed internally (important_instructions.docx).

Answer: *[Extracted from specific log hashes matching important_instructions.docx]*

Q14: What is the MITRE persistence technique ID used by the attacker?

Auditing persistence vectors involved hunting inside Sysmon Registry monitoring events (Event IDs 12, 13, 14). A modification pattern emerged where an alphanumeric payload key was dropped inside a generic runtime registry hive to maintain access upon reboot cycles.

Answer: T1547.001

Q15: What protocol is used to perform host discovery?

Network mapping phases were traced back to the primary compromised asset (192.168.10.15). Looking closely at low-level network records handled by Zeek and Suricata during this timeline window revealed an aggressive volume of probing packets.

Answer: ICMP

Q16: What is the email service used by the company?

Because application layer mail trails weren't directly exposed as native protocol tags, browser histories and external network resolutions were evaluated. Investigating web requests over port 443 combined with passive infrastructure intelligence via DNS verification confirmed the destination provider.

Answer: office365

Q17: What is the name of the malicious file used for the initial infection?

Correlating data from the initial execution sequence verified that the delivery mechanism for the initial macro or exploit package arrived as a decoy document.

Answer: important_instructions.docx

Q18: What is the name of the new account added by the attacker?

To discover systemic backdoors, user management events were audited. Filtering explicitly for Windows Security Event ID 4720 (A user account was created) surfaced a singular, unauthorized user creation log entry.

Answer: rambo

Q19: What is the PID of the process that performed injection?

Tracking Sysmon Event ID 8 (CreateRemoteThread) on the compromised host machine pinpointed an unverified binary (FSETPBEUslek.exe) injecting code threads directly into the active memory layer of an editing application (notepad.exe).

Answer: 7384

Q20: What is the name of the tool used for lateral movement?

Analyzing command-line execution patterns across adjacent networks surfaced highly distinct administrative templates indicative of a standardized exploitation framework (matching native Impacket administrative runtime patterns).

Answer: wmiexec.py

Q21: Attacker exfiltrated one file, what is the name of the tool used for exfiltration?

Isolating administrative commands executing concurrently with the external threat origin (192.20.80.25) under Sysmon Event ID 1 revealed an explicit upload sequence extracting a corporate document to an external server port using curl.

Answer: curl

Q22: Who is the other legitimate domain admin other than the administrator?

Privileged identity contexts were identified by filtering target access logs under Windows Security Event ID 4672 (Special privileges assigned to new logon), exposing active administrative identities.

Answer: adam

Q23: The attacker used the host discovery technique to know how many hosts available in a certain network, what is the network the hacker scanned from the host IP 1 to 30?

Correlating the internal network mapping indicators from the initial victim machine (192.168.10.15) verified that the probe sweep was targeting an adjacent local subnet.

Answer: 192.168.20.0

Q24: What is the name of the employee who hired the attacker?

Analyzing the explicit naming convention of the proprietary spreadsheet file exfiltrated via curl (sami.xlsx) confirmed the identity of the insider providing assistance.

Answer: sami

3. MITRE ATT&CK MAPPING

TECHNIQUE ID	TECHNIQUE	OBSERVED ACTIVITY
T1566.001	Phishing: Malicious Attachment	Delivery of <code>important_instructions.docx</code> to compromise employee endpoints.
T1055.002	Process Injection: Portable Executable Injection	<code>FSETPBEUsIek.exe</code> spawning threads directly inside active memory spaces of <code>notepad.exe</code> .
T1018	Remote System Discovery	Subnet scanning via ICMP protocols to discover neighboring operational hosts.
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys	Persisted malicious keys mapped into <code>HKU.DEFAULT\...\Run\SsGHOMcjsj</code> .
T1047	Windows Management Instrumentation	Executing remote process controls across target boundaries using <code>wmiexec.py</code> .
T1136.001	Create Account: Local Account	Execution of unauthorized user creation (<code>rambo</code>) logged via Event ID 4720.
T1562.001	Impair Defenses: Disable or Modify Tools	Querying local registries for <code>ScriptBlockLogging</code> parameters to evade text auditing rules.
T1048.003	Exfiltration Over Alternative Protocol	Transferring corporate data structures (<code>sami.xlsx</code>) externally via curl operations over port 8000.

4. CONSOLIDATED IOC SUMMARY

TYPE	VALUE	CONTEXT
IP	<code>192.20.80.25</code>	Remote Threat Actor Control Node
IP	<code>192.168.10.15</code>	Patient Zero Endpoint (Infected Node belonging to <code>nour</code>)
IP	<code>192.168.20.20</code>	Corporate Domain Controller
Host	<code>MGNT-01 (192.168.13.11)</code>	Secondary target hopped during lateral movement phases
File	<code>important_instructions.docx</code>	Initial attachment vector used for workstation weaponization

TYPE	VALUE	CONTEXT
File	sami.xlsx	Corporate asset targeted and stolen by external threat channels
Registry	...\Run\SsGHOMcjsj	Persistence auto-start vector modified on compromised systems
Username	sami	Internal threat actor / Compromised facilitator account
Username	rambo	Rogue backdoor account generated by the threat actor

5. KEY SIEM / EVENT QUERIES REFERENCE

Isolation of User Directory Discovery Artifacts

Payload Matches Regular Expression '(?i)project\d+'

Analysis of Evasion Vectors on Script Logging Policies

Payload Matches Regular Expression '(?i)ScriptBlockLogging'

Auditing Persistence Key Generation Inside Systems

EventID IN (12, 13, 14) AND TargetObject Matches '.*\CurrentVersion\Run\.*'

Tracking Unsanctioned Account Generation Ingress

EventID = 4720

6. ANALYST NOTES & INVESTIGATION METHODOLOGY

- **High-Level Category Prioritization:** When analyzing a major corporate incident, start by grouping events by high-level categories (such as *Suspicious Activity*). Sorting these chronologically in ascending order provides an efficient, reliable layout to identify Patient Zero.
- **Deep Payload Inspection for Evasion Tactics:** Threat actors systematically attempt to query or manipulate system registry paths like `HKLM\...\PowerShell\ScriptBlockLogging` to check for active auditing controls. Analysts should build proactive alerts catching queries aimed at these specific defense keys.
- **Cross-Process Thread Auditing:** Active monitoring of Sysmon Event ID 8 (`CreateRemoteThread`) is a critical control for catching process injection. Legitimate applications like `notepad.exe` establishing persistent network sockets to core assets like Domain Controllers should be immediately isolated.
- **Analyzing Lateral Movement Patterns:** Keep track of structured command formats like `cmd.exe /Q /c ... 1> \\127.0.0.1\ADMIN$\_ *`. This predictable syntax format is heavily tied to open-source toolkits like Impacket (`wmiexec.py`) and serves as a strong signature for active internal movement.